GitHub Account Security Guide

Best practices for Securing your GitHub Account

Table of Contents 📖

Introduction 2
Account Authentication 2
Email Account Security 3
Session & Device Security 5
SSH Key Security 5
Token Security 6
Repository Security 7
Monitoring & Alerts 7
Incident Response 7
Security Checklist 7
References 8

GitHub

Introduction

This document comprises of a clear overview of best practices for securing a GitHub account. Each section explains in detail all necessary aspects of GitHub that need to be secured and exactly how that can be done.

Account Authentication

Passwords

Creating strong passwords is essential in keeping any account secure and protected. **All passwords should be at least:**

- Eight characters long, *if* it includes numbers, lowercase as well as uppercase letters
- Or fifteen characters long with any combination of characters

<u>What NOT to do =</u>

- Do not repeat passwords from other accounts.
- Do not create a password less than the above criteria.

<u>What to do instead =</u>

- Create a unique password yourself, or use a password manager to generate a truly random password
- Store your unique password in a secure location such as a password manager

2FA

Configure two-factor authentication to your personal account for extra protection. This way the only way someone can sign into your account is if they have both your password *and* access to the authentication code on your personal phone.

2FA can be incorporated by completing the following steps:

- Sign in to GitHub
- Go to “Settings” > “Password and authentication”
- Click “Enable two-factor authentication (2FA)”
- Download an external authenticator app, such as Microsoft authenticator or the like
- Using the authenticator app, scan the QR code shown after you’ve clicked “Enable two-factor authentication (2FA)”
- Once you’d followed the instructions, you will receive a list of extra recovery codes as well, in case your personal phone is lost or inaccessible. This should be securely saved (preferably in a password manager).

Additionally, there are three other 2FA methods: **passkeys, security keys,** and **securing through GitHub mobile**.

- **Passkeys** are the perfect combination of having a password and 2FA all in one. It’s a way to sign in with one step while also having 2FA. This is done using touch, facial recognition, device password, or a specific PIN.
- **Security keys** are used for high
- er security where another physical device is needed to sign in. This is done by tapping the security key (the other device) using touch, PIN, or biometric proving you have the physical key.
- **Securing through GitHub mobile** is another convenient way of incorporating 2FA by simply approving sign-in requests directly from your phone. When signing in, you receive a push notification from the app itself, that you can then approve to gain access.

Email Account Security

Your GitHub account will always be linked to at least one of your email accounts. It is essential that this email account is also secured, as it being compromised also means your GitHub account and any other accounts associated with that email being compromised as well.

Core email security principles:

- Strong passwords
- Details of this, in section “Account Authentication”.
  - 2FA
- Through the email provider’s security settings, using a similar system discussed in section “Account Authentication”.
  - Connected devices / accounts
- Removing all unnecessary connected accounts and devices linked to the email. Connected devices / accounts being compromised in the future again leaves the risk of all other connected accounts being compromised as well.
  - Login alerts

- Enable login alerts to stay aware of all account activity and be able to spot any suspicious action before it's too late.
  - Account recovery options
- Ensure a backup email and phone number are added for account recovery. This should be separate from the primary accounts information to ensure backup is still possible in the case of a security incident.
  - Backups
- Ensure all backup accounts are equally secure. This means also following all the security measures for the backup email account.

Phishing awareness

Phishing through emails is one of the most effective cyber attacking techniques, even for those who already have a secure account. These attacks trick users into revealing credentials or unknowingly approving malicious actions. Below are a few tips that will help identify potential scams:

- Unexpected / urgent messages

Be aware of emails with a sense of urgency such as threats of account suspension if you do not click on a specific link and do a specific action (often leading to credentials being exposed), or any requests for immediate action. Especially when the email is urging you to immediately click a link or attachment of some sort to resolve the issue.

- Suspicious sender details

Be aware of where emails are coming from. Attackers will often use look alike domains or emails, but there will be slight differences (spelling mistakes etc).

- Unusual links / attachments

Be aware of unusual attachments in emails, and at all costs, avoid clicking or downloading anything without verifying first that it is safe.

- Requests for sensitive information

Be aware of emails that request sensitive information. Legitimate services will never ask for passwords, recovery codes, or other sensitive information over email.

- Poor formatting

Phishing emails will often have grammatic errors, inconsistent branding, and other formatting mistakes. At times these are very minor however, and a good eye is needed to spot them.

- Login / security prompts

Phishing emails will also use the technique of claiming there is a security issue and urging re-login using a specific link or the like to ‘protect your account’. In such cases,

always access your account or service using the official website rather than any links or attachments provided in the email. If unsure as to whether something is a scam or not always contact the relevant organization separately for clarification.

- Unexpected approval requests

Be aware of any login or 2FA approval prompts. Unless you are the one trying to log in, anything of this sort should never be approved.

Session & Device Security

Even with strong passwords, 2FA and a secure email, compromised devices and sessions also leave room for GitHub account breaches. Session and device security ensure that only trusted devices are used, and sessions are controlled and monitored.

Key device security practices:

- Only use personal or company-managed devices. Public devices should never be used to access personal accounts.
- The device should be protected with a strong password.
- The device should be regularly updated. These include operating system update installation as well as browsers, antiviruses, etc.
- The device should have an antivirus that can detect suspicious activity and protect the device.
- Immediately sign out of your GitHub account or revoke access to devices that you are no longer using or devices that have been lost or stolen.

Key session security practices:

- Check active GitHub sessions and identify anything unknown or suspicious.
- Revoke or sign out of any unused sessions immediately.
- Never stay signed in on shared devices.

SSH Key Security

SSH keys are used to authenticate access to GitHub repositories without the need for a username or password. SSH keys consist of two parts:

1- Private key = this is on your personal device and must NOT be shared
2- Public key = this is added to the GitHub account and is safe to share

GitHub then checks that the keys match, and then you're given access. This method is only used when interacting with GitHub from the command-line.

SSH keys provide direct and password-less access to GitHub, which is why this needs to be treated as a high-risk security issue.

SSH key security practices:

- Key generation
  - Always use modern and secure algorithms when generating the key.
  - Create a separate unique SSH key for each service needing one (NEVER re-use SSH keys).
- Key protection
  - Never share your private key anywhere (this includes your GitHub repositories and the like).
  - Keey your key stored on trusted devices.
  - Ensure you have a strong passphrase for the private key. This way, it remains encrypted.
- Key management
  - Keep track of the SSH keys associated with your account (under Settings > SSH and GPR keys).
  - Remove all unused / outdated keys.
  - Only have SSH keys to accounts that require repository access.

Token Security

A token is also used to authenticate access to GitHub without the need for an actual interactive login. This method is used when interacting with GitHub through pipelines, APIs, and other third-party integrations. The token consists of:

- A single secret value generated by GitHub.

The token is presented to GitHub; GitHub verifies the token, and access is granted in that way.

Tokens provide direct and password-less access to GitHub, which is why this needs to be treated as a high-risk security issue as well.

Token security practices:

- Follow all SSH key security practices as they are all applicable for tokens as well.
- Tokens Expiry date
  - Always add an expiry date for the tokens and then rotate them on a regular basis.
- Tokens access
  - Always limit tokens access to only what is necessary (the necessary repositories only).
- Token storage
  - Tokens should never be stored in source code, or plaintext anywhere

Repository Security

Repositories store source code and project data and must be secured to prevent unauthorised access or malicious changes.

Key repository security practices:

- Only give repository access to people who need it and remove access when it is no longer required.
- Make sure the repository is set to public or private on purpose
- Protect the main branch so changes cannot be made directly
- Make all changes through pull requests and review them before merging
- Do not store passwords, keys, or other sensitive information in repositories
- Turn on GitHub security features where available

Monitoring & Alerts

Monitoring helps you notice unusual activity before it becomes a serious issue.

Key monitoring and alert practices:

- Turn on Github alerts for logins, security issues, and updates
- Regularly check activity such as changes to code or repository settings
- Look into anything that seems unexpected or unfamiliar
- Do not ignore security alerts, even if nothing looks wrong at first.

Incident Response

Incident response is the process of reacting quickly when something goes wrong

Key incident response practices:

- Act immediately if you think your account or repository has been compromised
- Change your password and remove access you do not recognise
- Disable or replace any exposed keys or tokens
- check recent activity to see what was changed
- Fix or restore any affected files and secure the repository again
- Take steps to prevent the issue from happening again

Security Checklist

To keep your GitHub account secure you can follow a checklist

Security Checklist:

- Use a strong, unique password
- Enable two-factor authentication
- Secure the email linked to you GitHub account
- Limit and review who can access your repositories
- Protect the main branch
- Never store sensitive information in repositories
- Turn on GitHub security alerts
- Review keys and tokens regularly
- Investigate anything suspicious right away

References

Keeping your account and data secure - GitHub Docs. (2026). GitHub Docs.

https://docs.github.com/en/authentication/keeping-your-account-and-data-secure

Code security documentation. (n.d.). GitHub Docs.

https://docs.github.com/en/code-security

Configuring Dependabot alerts - GitHub Docs. (2026). GitHub Docs.
https://docs.github.com/en/code-security/how-tos/secure-your-supply-chain/secure-your-dependencies/configuring-dependabot-alerts